

Digital Twins in Industry 4.0 and the Built Environment: A Deep Dive into Security Architectures, Advanced Threats, and Defensive Strategies

Ali Muntazir
Mehdi Kharal
u2023098@giki.e
du.pk

M. Ismail
u2023453@giki.e
du.pk

M. Abubakar
u2023352@giki.e
du.pk

Abdullah
Ahtasham
u2023033@giki.e
du.pk

Ghulam Ishaq Khan Institute of Engineering Sciences and Technology Department of Cyber Security

Abstract—The Digital Twin (DT) has transitioned from being a concept for aerospace simulations only to a widely used technology that is the main driver of Industry 4.0 and Smart Cities. DTs, through the creation of a high-fidelity, real-time virtual duplicate of physical assets, are the source of a large number of benefits in predictive maintenance, operational optimization, and disaster recovery. However, the coupling of OT with IT networks in this manner results in a huge, mostly unprotected, potential area for attacks. This exhaustive review goes through the security of DTs in the industrial and B.

We analyze the four-layer functional architecture of DTs in detail and identify the types of threat that can range from physical sensor spoofing up to sophisticated AI model poisoning. We also conduct a critical assessment of the "Cyber Digital Twin" (CDT) as a security tool, pointing out its ambiguous role as both a environment for security experiments and a tool for the adversaries to gain knowledge.

At last, we formulate a set of strong recommendations, among them the use of ISO 19650-5 for secure Building practice.

Index Terms- Digital Twin, Cybersecurity, Industry 4.0, Building Information Modeling (BIM), Smart Cities, Cyber-Physical Systems, Internet of Things (IoT), Blockchain.

I. INTRODUCTION

The idea of Digital Twin (DT) is not a new idea of the 21st century; the history of the concept goes as far as to the 1970s when NASA used "mirrored systems" to keep track of the physical parts of the space missions [1]. The fabulous, earliest, and most famous application was the Apollo 13 incident, where engineers on the earth used the simulated physical environment to model the solutions before sending them to the broken spacecraft [1]. However, the DT has now evolved to be a highly detailed virtual model of any real-world entity, be it a single product, a complicated manufacturing process, or a whole city system, which is updated with the specified frequency and the level of accuracy to reflect the life of its physical counterpart [3], [1].

In the time of Industry 4.0, DTs are the key mechanisms of "Factories of the Future." DTs, by combining Cloud Computing, the Internet of Things (IoT), Big Data analytics, and Artificial

Intelligence (AI), grant forecast of system states, improve production lines, and fault machines prediction even before the occurrence of the breakdown to the operators [4]. The same way, the Built Environment is going through a transformation where static building data from Building Information Modeling (BIM) is being combined with live IoT feed to generate adaptable models for the management of Smart City eco-systems, e.g., from traffic grids to water utilities [3].

A. The Security Gap

However, the extensive use of DTs has gone far ahead of the establishment of security frameworks, which is somewhat contradictory to the operational benefits. Essentially, the main feature of a DT is the Digital Thread that represents the continuous, two-way data exchange between the real and the virtual worlds [1]. Such a link, however, exposes the DT to a very different kind of risk than before: a cyberattack is no longer just about stealing data, it may lead to physical destruction. In other words, we are linking old Operational Technology (OT) systems that have been around for maybe 30 years and were never designed for encryption or authentication with modern, internet-facing IT networks [2]. This manuscript is a step towards realizing the difference between the implementation of DT and cybersecurity.

II. TAXONOMY AND ARCHITECTURAL FRAMEWORKS

In order to find the security holes, we must first understand the building of Digital Twins. They are not a single technology but a stack of integrated layers and different definitions.

A. Taxonomy of Digital Artifacts

Confusion often exists between different types of digital representations. Research provides a crucial taxonomy based on the level of data integration [2]:

There is often confusion between various kinds of digital representations. The research offers an

important classification which is based on the extent of data integration [2]:

1) **Digital Model:** This refers to a manual integration. There is a digital representation but the changes in the physical object are not automatically reflected in the digital version, and changes in the digital version do not influence the physical object. Thus, it is basically a static model.

2) **Digital Shadow:** This is about an automated one-way data flow from the physical object to the digital object. The change in the physical asset is therefore, immediately visible in the digital viewer, but the digital viewer has no capability to control the physical asset.

3) **Digital Twin:** This means a fully automated, bi-directional data flow. Besides reflecting the physical state, the digital object can also be used to make changes in the physical object (for example, a simulation detecting an anomaly and automatically issuing a command to the machine to shut down) [1]. It is this bi-directional control that brings the highest security risk.

B. The Four-Layer Functional Architecture

In essence, a thorough security analysis therefore implies that we will have to decompose the Digital Twin into four primary layers [2]:

1) Layer 1 Data Dissemination and Acquisition.

This is the “eyes and ears” part and it is at the Physical Space. It consists of the entire sensors and actuators and RTUs and PLCs. We use CPS/IIoT protocols (think about Modbus, ZigBee, WirelessHART) to transform the real world into the digital world [2]. The catch? The majority of those protocols do not come with any built-in encryption, and therefore, they are

completely vulnerable to eavesdropping and replay attacks.

2) Data Management and Synchronization layer

In this case, we are crossing a physical and an online world. This layer deals with the normalization, enrichment and administration of the network. It is the gate way and it ensures that all the various data sources are brought up to date correctly. It is important to maintain the Digital Thread. When sync traverses a river, like either due to lag in the network connection or the result of a direct attack, the twin becomes desynced, and decisions are being made on out-of-date information [2].

3) Layer 3: Modeling & Services

This is the cerebral Space of the Digital. It contains the geometric, kinematic, and logical models, simulation engines and AI algorithms that predict future states. It also operates predictive maintenance and diagnostics services [2]. The risks in this case are IP theft and the so-called model poisoning when the AI is trained on harmful data.

4) Layer 4: Visualization & Access

Lastly, this layer provides interfaces to the twin to folks, such as human operators and external systems such as ERP or MES. It displays actionable insights with the help of HMIs, AR, and VR. The greatest danger is the threat of visualization tampering whereby attackers manipulate the display to deceive the operators [2].

C. Architectures in the Built Environment

The sectors of construction and smart city have an architectural style that is characterized by the use of Building Information Modeling (BIM). In a way, BIM offers a detailed semantic database of a building's design and parts (e.g., IFC files) but it has been conventionally without the dynamic linkage of the IoT [3].

Smart City Reference Zones: The study of eight leading European smart cities—Antwerp, Carouge, Eindhoven, Helsinki, Manchester, Milan, Porto, and Santander—shows a fragmented architectural landscape [3].

Santander & Porto make use of open-source platforms such as FIWARE for the management of IoT data streams. Manchester has put in place an API management system that utilizes the OAuth2 protocol for the purpose of identity management. While these "Reference Zones" have made a lot of progress, they are mostly devoid of a specifically designed and integrated cybersecurity layer. The most common ones depend on general web security standards (such as HTTPS) which are not enough to safeguard the most important parts of the infrastructure against highly skilled state-level attackers [3].

III. CRITICAL OPERATIONAL REQUIREMENTS

If a Digital Twin is to be a reliable one in scenarios of critical infrastructure (such as power grids or hospitals), then it should satisfy certain operational criteria. Knowing what these criteria are helps understand the consequences of the cyberattacks because, in fact, each attack represents an infringement of one or several of these pillars [2]:

1) Fidelity and Granularity: The DT must be able to represent not only the physical but also the behavioral aspect of the hardware. A situation where the data fed by sensors have

been tampered with (Integrity attacks) is one where the DT loses its fidelity, thus making the instrument either useless or dangerous.

2) Synchronization: The coordination of the two different spaces in real-time is of utmost importance. Issues here can cause "latency jitter" which is a phenomenon in which the twin is actually representing an old state. For example, in high-speed manufacturing, the delay of even a few milliseconds can lead to a physical collision if the machinery is under the control of the twin.

3) Interoperability: A DT rarely is fully independent. For instance, a DT might be present in a Cloud, Fog, and Edge computing environment, and the devices involved may be of differing types and models. Hence, security protocols should provide for the unhindered interaction of these various systems without posing any restrictions on the exchange of information.

4) Reliability: The system has to be capable of providing the right service on a continuous basis. Besides Availability (being able to access resources) and Maintainability (performing updates with ease), this situation also assumes a denial-of-service scenario, in which the availability of the twin is the target and the result is a factory being compelled to stop its work or return to manual operations.

IV. COMPREHENSIVE THREAT LANDSCAPE

The threat environment of digital twins (DTs) is wide and includes physical tampering, network exploits, and complex data manipulation. We classify these threats according to the layer they target.

A. Layer 1: Physical and Network Threats

The physical layer is essentially the first target of hackers, as a consequence of the influx of cheap, insecure IoT devices.

Rogue Devices: In order to manipulate physical systems, attackers can plant malicious sensors or create clones of legitimate ones to inject false data without being detected. For example, a rogue sensor in a manufacturing environment can report that the temperature is normal while a machine is overheating and, as a result, physical failure and fire can cause huge losses [2].

Denial of Service (DoS): Limited IoT devices such as those running on battery power are very vulnerable to attacks aimed at flooding the devices with requests. A DoS attack can disrupt the Digital Thread, thus the digital twin loses its ability to monitor the physical asset's state [1]. In the absence of this real-time link, the twin turns into a "stale" model, which has no practical use.

Legacy Vulnerabilities: A great number of OT devices are using the outdated firmware and are based on insecure protocols such as Modbus TCP, which sends data in an unencrypted manner. The malware campaigns that the authors refer to, like Stuxnet, Black Energy, and Triton, have been the major factors that exploitation of these weak points to gain access to control logic and ultimately cause physical damage to centrifuges and power grids have been the most directly [2].

B. Layer 2 & 3: Digital Infrastructure Threats

The DT logic Cloud/Edge computing infrastructure that hosts the DT logic is a prime target for IP theft and sabotage.

- **Desynchronization Attacks:** If attackers deliberately falsify network traffic or put artificial delays, they can make sure that the digital twin is very different from reality. In case the DT goes for automated control (closed-loop), such disconnection may cause the physical system to function according to the wrong parameters, thus resulting in it becoming unstable [1], [2].

- **AI Data Poisoning:** In case the Digital Twin is supported by Machine Learning for predictive

maintenance, the attackers can include malicious samples in the training data ("poisoning") so as to fool the model to overlook certain failure modes or to treat dangerous anomalies as normal behavior [2], [4].

- **Intellectual Property (IP) Leakage:** The first thing a high-fidelity DT is, is the "DNA" of the industrial processes, trade secrets, and production recipes. A breach in the virtual world can let the enemies take this IP without physically going to the facility. This, in the case of automotive or aerospace industries, can lead to a huge economic risk [2], [4].

C. Layer 4: Visualization and Human Threats

- **Visualization Tampering:** Attackers are able to break into the HMI so as to show fake data to the human operators. In a 'deception attack', the HMI may be displaying a stable green 'All Clear' light whereas the actual system is physically in a critical alarm state. As a result, it stops the human operators from coming to the rescue to prevent the accident [1], [2].

- **Privacy Leakage:** In Smart Cities, DTs collect a huge volume of data related to citizens. If there are no necessary protective measures, this data can be re-identified thus making it possible to follow the locations and behaviors of individuals, which is a breach of privacy regulations such as GDPR [3].

D. The Cascading Effect

The cascading nature of the heavily interlinked threats has been one of the most critical features that have been discussed. In the most basic example when a sensor is compromised, the security issue would propagate to the higher layers since the affected layer 1 will be out of sync with layer 2, the model in layer 3 and the visualizations in layer 4 will all be impacted

indirectly. On the other hand, if a command injection is performed at Layer 4 it may trickle down to the point where the actual equipment at Layer 1 may be physically damaged thereby causing a cascade of events to occur [2].

V. THE CYBER DIGITAL TWIN (CDT): DEFENSE AND RISK

The Cyber Digital Twin (CDT) is a specialized DT technology application which is not aimed at modeling the physical process, but rather the cybersecurity posture of the system [1].

A. CDT as a Defensive Tool

CDTs offer a secure isolated "sandbox" environment for security activities:

- **Intrusion Detection:** With physics-based modeling, a CDT may be used as a baseline for "normal" behavior (e.g., through a Kalman filter). If the real system is operating in a way that is different from the simulation (e.g., a valve is opening faster than physics dictates), it is a very strong signal of a cyberattack [1].

- **Patch Management:** The process of security patching industrial devices is fraught with risks that may lead to the equipment going out of service. CDTs enable security staff to try the patches of the virtual duplicate first, thus securing the actual deployment without any interruptions to the operations [1], [4].

- **Threat Hunting:** With CDTs, security analysts are able to create various scenarios of attack (e.g., ransomware propagation) so as to uncover the weakest points of the network topology as well as confirming the effectiveness of incident response plans without the risk of the live plant being done [4].

B. The "Double-Edged Sword"

Nevertheless, the CDT also carries substantial risks. It is referred to as a "double-edged sword" [1]. An attacker having access to the CDT will have a detailed blueprint of the vulnerabilities, security configurations, and patch levels of the system. Thus, they can "wargame" the attacks in the simulator until they achieve the utmost accuracy, thereby making the occurrence of a hit on the physical infrastructure highly probable. In addition to this, the intricacy of the CDT maintenance escalates the possible overall attack surface since the security tool, in this case, is another software stack that needs to be patched and secured [1].

VI. RECOMMENDATIONS AND BEST PRACTICES

A multi-layered security strategy, which encompasses technical solutions as well as governance frameworks, is necessary to reduce these risks.

A. *Enhancing Standards for the Built Environment*

Present building information modeling (BIM) standards such as IFC and COBie are primarily oriented towards aspects of the design and geometry of the model and do not take into account the issue of security [3].

- ISO 19650-5: Organizations operating in the built environment should conform to the requirements of ISO 19650-5:2020. This standard offers the structure for security-conscious information management, which supports the organizations in recognizing the most sensitive assets and, thus, applying appropriate security measures at every stage of the project lifecycle [3].

- IoT-Compliant BIM: The specification of building information modeling needs to be expanded to accommodate the dynamic Internet of Things data natively through the research effort. Presently, BIM is a non-changing one;

therefore, augmenting it to cope with the sensor streams in real time in a secure way necessitates the development of new schemas that not only integrate cryptographic identifiers (for example, the Handle System) but also incorporate them as an inherent part of the BIM objects [3].

B. *Technical Mitigation Strategies*

- Blockchain Integration:

Distributed Ledger Technology (DLT) is an excellent tool to ensure data integrity. By saving all transactions and data interactions between twins on a blockchain, companies can guarantee traceability and rule out the possibility of history being changed. Thus, an unalterable audit trail is laid down which is very important for the investigation process after an incident [2].

- Privacy-Enhancing Technologies (PETs):

To secure confidential data in Smart Cities and healthcare DTs, PETs like differential privacy and data obfuscation should be implemented. It grants the use of data for macro-level analysis without the risk of revealing individual identities [3], [4].

- Encryption and Authentication:

The implementation of strong encryption (AES, 3DES) and mutual authentication should be done for all communication channels in the Digital Thread. Insecure protocols such as Modbus should be enveloped in secure tunnels (e.g., TLS) or reconditioned with modern secure alternatives like OPC-UA [2], [3].

C. *Operational Governance and Ethics*

- Security-by-Design: It is explicitly mandated that security should be one of the central features of the design of the DT in the very first phase, rather than being a by-product of the later stages. Among the features this refers to are very strict access controls as well as limiting the potential

attack surface by closing those services which are not needed [4].

- **Ethical Frameworks:** In case AI-powered DTs are given the capability to make decisions independently, then the incorporation of ethical principles becomes obligatory in order to guarantee that the decisions are fair and that the decision-makers are accountable, especially in cases when the outcome is the safety of humans [4].
- **Skills Training:** The "human factor" is still the most fragile part. The implementation of a complete training scheme is imperative in order to familiarize engineers and operators with the cyber risks in which the DTs are involved. The use of CDTs as "cyber-ranges" can be a tool through which employees get the opportunity to undertake drills in a virtual and hence safe environment but with the utmost realism in the manner of response to the attack [4].

VII. CONCLUSION

REFERENCES

- [1] D. Holmes, M. A. Ferrag, M. Papathanasakis, S. Nepal, L. Maglaras, and H. Janicke, "Digital Twins and Cyber Security - solution or challenge?," in 2021 6th South-East Europe Design Automation, Computer Engineering, Computer Networks and Social Media Conference (SEEDA-CECNSM), Preveza, Greece, 2021.
- [2] C. Alcaraz and J. Lopez, "Digital Twin: A Comprehensive Survey of Security Threats," *IEEE Communications Surveys & Tutorials*, vol. 24, no. 3, pp. 1475-1503, 2022.
- [3] K. Alshammari, T. Beach, and Y. Rezgui, "Cybersecurity for digital twins in the built environment: current research and future directions," *Journal of Information Technology in Construction (ITcon)*, vol. 26, pp. 159-173, 2021.
- [4] A. J. G. de Azambuja et al., "Digital Twins in Industry 4.0 – Opportunities and challenges related to Cyber Security," *Procedia CIRP*, vol. 121, pp. 25-30, 2024.

The Digital Twin is a radical change to Industry 4.0 and the built environment, providing unmatched insight and control. With it, we can make entire cities more energy efficient and machines can be prevented from breaking down without a prior failure. But, in the same time, it raises the cyber-risk landscape as it creates a very detailed connection between the physical and digital worlds. On the one hand, DTs are strong defense tools when considering Cyber Digital Twins, on the other hand, they may become the highest-value targets which in turn expose the most sensitive operational information and make it easier to conduct physical sabotage. Protecting this model heavily relies on a comprehensive strategy that is not confined to conventional IT security. The transition to physical security, ensuring data integrity through blockchain, and using security-conscious standards like ISO 19650-5 characterize the essence of this holistic approach. The only way to fully safeguard against the risks of the Digital Thread is to recognize that the gains of virtualization should not be at the sacrifice of operational safety and national security.